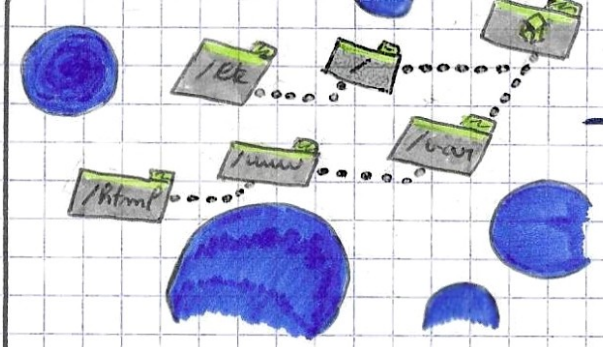


Inclusion De Fichiers

Catégorie : Offensif
Difficulté : Medium, Burp
Durée Estimée : 8 Heures

Introduction à l'Inclusion de Fichier:

La LFI est une vulnérabilité web ou un attaquant peux manipuler l paramètres d'une requête HTTP (comme langage=fr) pour forcer l'applica à charger et afficher des fichiers locaux sur le serveur. Cela se produit lor que l'entrée utilisateur n'est pas correctement validé avant d'etre utili et dans une fonction qui inclut des fichiers
Cette vulnérabilité peux mener à la diffusion de code source donnés sen bles et dans certains cas à la RCE.
Il est crucial de se renseigner et faire la différences entre les fonctions qu lisent seulement le fichier et celles qui exécutent le code qu'il contient, mo ment lors de pentest white box ou de l'analyse de code.

Pour lire un fichier une fois qu'une LFI est detecté on peux procéder e spécifiant le chemin absolu, ou encore à l'aide d'une remontée de repert (Ex ../../../etc/passwd)

Attaques de Second Ordre:

C'est une autre LFI courante et plus avancé, elle se produit car de n breuses fonctionnalités d'une application web peuvent récuperer de manière n sécurisée des données du serveur back-end en se basant sur des paramètre contrôlés par l'utilisateur. Par exemple une application web qui permet de t léchargez un avatar via (/profile/$ username/avatar.jpg) si on crée un nom d'utilisateur malveillant (ex: ../../../etc/passwd) qui "pollurait" une entr de la base de donnée, ensuite une autre fonctionnalité y ferait appel et menerai à son exécution...

Basics Bypass

Un des filtres les plus basiques est un filtre de recherche et remplacement qui supprime les (../) mais ce filtre peux etre facilement trompé si il ne filtre l'entrée et laisse aller la sortie l'exemple suivant montre le filtre et comme reconstituer une sortie en remontée de repertoire ...// un autre exemple rait ..../../ ou ....// ou encore .... ////
Certains filtres peuvent également être contournés en appliquant un encodage URL à notre payload, on peux même appliquer un double encodage URL, l'enco de Burp est un bon outil pour se faire

Certains filtres utilisent un regex pour s'assurer que la ressource demandé est dan le dossier adéquat, si on parvient a trouver ce dossier on peux parvenir à stipu un chemin qui en part et remonte les repertoires Ex =./langues/../../etc/p sud, bypassant ainsi les filtres.
Certains filtres pourraient malheureusement nous limiter à une exécution bien pa cise... Les filtres peuvent etre bypasser avec des versions ancienne de php... avec d techniques comme le null byte (%00) ou la limitation à 32bits, (4096 caracter chaines de caractères.